

CYBER SECURE SOLUTIONS

Gestion d'une attaque par ransomware

Type: plan_reponse_ransomware

Date: 3/30/2025
Référence: Gestion de crise cyber
Destinataire: eddy

****Document Technique : Plan de Réponse à une Attaque Ransomware****

****Domaine : Gestion de crise cyber****

****Scénario : Gestion d'une attaque par ransomware****

****Niveau de difficulté : Expert****

****Contact : Lorenzo Bertola****

****Destinataire : Eddy****

****Contexte****

Le 14 octobre 2023 à 08h15, des utilisateurs internes ont signalé une impossibilité d'accéder à leurs fichiers stockés sur le réseau partagé de l'entreprise. Les fichiers semblent avoir été chiffrés et portent une extension inhabituelle (.locked). Un message de rançon est apparu sur plusieurs postes utilisateurs et serveurs critiques. Ce message exige un paiement en crypto-monnaie (Bitcoin) sous 72 heures pour obtenir une clé de déchiffrement.

L'attaque a entraîné une interruption significative des opérations, y compris l'indisponibilité des services internes essentiels tels que l'accès aux bases de données clients, les outils de gestion de projet, et les serveurs de messagerie. Une partie de l'infrastructure cloud semble également être affectée.

****Enjeux****

1. ****Impact opérationnel**** : Dégradation des services internes et externes.
2. ****Risques financiers**** : Coût potentiel lié à la rançon, à la perte de données, et à la restauration des systèmes.
3. ****Risques juridiques**** : Conformité aux réglementations locales et internationales en matière de protection des données (RGPD, HIPAA, etc.).
4. ****Réputation**** : Risque de perte de confiance des clients et partenaires.

****Observations Techniques****

- ****Type de ransomware suspecté**** : Basé sur les indices (extension de fichier, format du message de rançon), il s'agit probablement d'une variante récente de "LockBit" ou "BlackCat". Ces familles de ransomware sont connues pour leur capacité à exfiltrer des données avant chiffrement.

- ****Vecteurs possibles d'infection**** : L'analyse initiale suggère que l'attaque pourrait avoir été introduite via un fichier malveillant reçu par e-mail ou une vulnérabilité non corrigée dans un service exposé sur Internet.

- ****Mécanisme de propagation**** : Le ransomware semble capable de se propager latéralement dans

le réseau à l'aide de techniques d'exploitation d'identifiants volés et de vulnérabilités dans les protocoles SMB (Server Message Block).

****Données Affectées****

- ****Serveurs critiques impactés**** :
 - Serveur de fichiers principal (\\fileserver01)
 - Serveur de messagerie interne (\\mailserver02)
 - Base de données clients (\\dbserver03)
- ****Postes utilisateurs impactés**** : 45 signalements provenant de différents départements.

****Historique et Références****

Les attaques par ransomware ont considérablement évolué depuis leurs débuts en 2013 (ex. CryptoLocker). Les variantes modernes, telles que celles suspectées ici, incluent souvent une phase de reconnaissance où les attaquants identifient les ressources critiques avant de déclencher le chiffrement. Ces attaques s'accompagnent désormais de tactiques de double extorsion : les données sont exfiltrées et menacées de divulgation, en plus d'être chiffrées.

****Exemples récents**** :

- Attaque contre Colonial Pipeline (2021) : Impact opérationnel majeur et paiement de la rançon.
- Attaque contre Kaseya (2021) : Exploitation d'une vulnérabilité zero-day et impact global via la chaîne d'approvisionnement.

****Actions Immédiates Requises****

1. ****Identification et confinement**** : Localiser les systèmes infectés et isoler les segments réseau touchés.
2. ****Analyse préliminaire**** : Obtenir une copie du ransomware et analyser son comportement (sandboxing, reverse engineering).
3. ****Communication interne/externe**** : Informer les parties prenantes clés (direction, équipes IT, partenaires).
4. ****Inventaire des sauvegardes**** : Évaluer l'état et la disponibilité des sauvegardes récentes.

****Informations Complémentaires****

- ****Contact technique**** : Lorenzo Bertola - Responsable Sécurité Informatique.
- ****Protocole de communication**** : Utiliser le canal de crise désigné (Slack privé ou téléphone sécurisé).
- ****Documentation disponible**** : Guide interne de gestion des incidents, liste des actifs critiques, et journal des mises à jour de sécurité.

****Note au destinataire (Eddy)**** : Utilisez les informations ci-dessus pour établir un plan de réponse structuré. Veuillez prioriser les étapes en fonction des impacts identifiés et des ressources disponibles. Évitez de se précipiter dans le paiement de la rançon sans avoir exploré toutes les alternatives.

